

# Authorized Web Application Penetration Test Report

Acme Health Demo | Authorized Web Application Penetration Test

Classification: Confidential | Version 1.1

## Executive Summary

This report documents an authorized security assessment of the Acme Health Demo web application environment. The assessment focused on defensive improvement, evidence-safe documentation, and practical remediation guidance.

| Severity      | Count |
|---------------|-------|
| Critical      | 0     |
| High          | 1     |
| Medium        | 1     |
| Low           | 0     |
| Informational | 0     |

## Technical Findings

### ***RF-002 - Administrative workflow lacks explicit detection coverage***

Severity: High | Likelihood: Medium | Status: Open

**Affected Asset:** Acme SIEM demo workspace

#### **Description**

High-impact administrative actions are logged, but alerting does not currently track unusual sequencing or out-of-hours changes.

#### **Impact**

Delayed detection of risky administrative activity can increase investigation time and reduce confidence during incident response.

#### **Recommendation**

Create detections for unusual administrative action chains and validate alert routing with synthetic benign events.

### ***RF-001 - Verbose error responses disclose internal service details***

Severity: Medium | Likelihood: Medium | Status: Open

**Affected Asset:** <https://api.demo.acme.example/v1/profile>

#### **Description**

Synthetic test requests produced verbose error responses that included internal route names, framework metadata, and correlation identifiers.

#### **Impact**

Excessive implementation detail can help an attacker refine reconnaissance and craft more targeted follow-up tests.

#### **Recommendation**

Replace verbose client-facing errors with generic messages and preserve detailed diagnostics in server-side logs.